Northwind Bank (fictional): Third-party security assessment

Supplier: _____ Completed by: _____ Date: _____

Instructions. Answer every question Yes, No, Partial or N/A, and explain any answer other than Yes in the Comments column. Attach supporting evidence where available. Return the completed form within 15 business days.

A. Access control

Ref	Question	Answer	Comments
A1	Is multi-factor authentication enforced for all administrative and console access?		
A2	Do you have processes in place to make sure access (both physical and logical) is revoked when an employee, intern, vendor, contractor, or other associate leaves the company or a project?		
A3	Are user access rights reviewed periodically?		

B. Data protection

Ref	Question	Answer	Comments
B1	Is data at rest encrypted?		
B2	Is encryption and integrity protection in place for all internal network traffic that potentially carries sensitive information?		
B3	Are any storage buckets publicly accessible?		

C. Security operations

Ref	Question	Answer	Comments
C1	Do you monitor your network for security events?		
C2	Do you have a process for installing operating system and application updates and security patches on servers?		
C3	Do you regularly test your backups?		
C4	Does an independent third party regularly perform penetration tests on all systems used to provide services to customers?		

D. People and incidents

Ref	Question	Answer	Comments
D1	Do employees complete security awareness training?		
D2	Are incident response procedures documented?		
D3	Do you inform affected customers about security incidents?		
D4	Is customer data stored in the EU only?		

Thank you. Questions about this form: vendor-risk@northwind.example